

BITEME JAPAN

운영 리스크 분석 리포트

대상 서비스: biteme.co.jp

작성일: 2026-06-05

작성 배경: 2026-06-04 Shopify API 장애 → 롤백 이후 전체 리스크 점검

전체 보안 점수: 3.1 / 10 ● 매우 위험

1. 어제 Shopify API 장애 원인 분석

근본 원인: Dev/Prod 토큰 방식 불일치

환경	방식	갱신	위험
개발	<code>client_credentials</code> 자동 획득	만료 5분 전 자동 갱신	안전
프로덕션	<code>SHOPIFY_STOREFRONT_TOKEN</code> 고정	갱신 로직 없음	장애 원인

```
// api/shopify.ts (프로덕션) - 토큰 갱신 코드 없음

const token = process.env.SHOPIFY_STOREFRONT_TOKEN;

if (!token) return res.status(500).json({ error: 'Missing token' });

// 토큰이 만료되면 재시도·폴백 없이 즉시 장애 → 전체 스토어 접근 불가
```

개발 환경(`server/shopify-proxy.ts`)은 토큰 만료 5분 전에 자동 갱신하지만, 프로덕션(`api/shopify.ts`)은 환경변수에 고정된 토큰을 그대로 사용합니다. 토큰이 만료되거나 무효화되면 **재시도·폴백 없이 즉시 전체 장애**로 이어집니다.

재발 방지 방향

현재: [요청] → 고정 토큰으로 Shopify 호출 → 토큰 만료 시 즉시 장애

개선: [요청] → 캐시된 토큰 유효 확인 → 만료 시 자동 갱신 → Shopify 호출

→ 실패 시 최대 3회 재시도 (지수 백오프)

개발 환경의 `getAccessToken()` 로직을 프로덕션에도 동일하게 적용해야 합니다.

2. 리스크 종합 점수

영역	점수	등급
환경변수 관리	1/10	● 긴급
Shopify 토큰/API	3/10	● 긴급
인증·인가	3/10	● 긴급
어드민 접근 제어	1/10	● 긴급
에러 처리·복원력	2/10	● 긴급
CORS·보안 헤더	5/10	● 주의
LINE 로그인	4/10	● 주의
데이터 저장	6/10	● 보통
전체	3.1/10	● 매우 위험

3. P0 — 즉시 처리 (48시간 이내)

3-1. 시크릿 키 즉시 교체 (최고 우선)

`.env` 및 `.env.vercel` 파일에 실제 시크릿 키가 하드코딩되어 있습니다. 이 파일들이 Git에 커밋된 기록이 있다면 이미 노출된 상태입니다.

키	교체 방법
SHOPIFY_CLIENT_SECRET	Shopify Admin → Apps → 새 키 발급
LINE_CHANNEL_SECRET	LINE Business Center → 채널 시크릿 재발급
ANTHROPIC_API_KEY	console.anthropic.com → 새 키 발급 후 기존 폐기
GOOGLE_SERVICE_ACCOUNT_JSON	Google Cloud IAM → 새 키 발급 후 기존 삭제
ADMIN_SECRET	"ilovebiteme!" → 강도 높은 랜덤 값으로 교체
SUPABASE_SERVICE_ROLE_KEY	Supabase 대시보드에서 재발급
GA4_API_SECRET	Google Analytics → 데이터 스트림 → API 시크릿 재발급

교체 후 필수 작업:

```
# .gitignore에 추가
echo ".env" >> .gitignore

echo ".env.vercel" >> .gitignore

echo ".env.local" >> .gitignore
```

```
git push --force
```

모든 시크릿은 Vercel 대시보드 환경변수(UI)로만 관리하고, `.env` 파일은 `.gitignore`에 포함시킨 뒤 로컬에서만 사용하세요.

3-2. Shopify API 토큰 자동갱신 구현 (어제 장애 재발 방지)

대상 파일: `api/shopify.ts`

현재 프로덕션 코드에는 토큰 갱신 로직이 없습니다. 개발 환경(`server/shopify-proxy.ts`)의 `getAccessToken()` 패턴을 프 로덕션에도 동일하게 적용해야 합니다.

개선 방향:

- 토큰 캐싱 + 만료 5분 전 자동 갱신
- API 호출 실패 시 최대 3회 재시도 (지수 백오프: 1s → 2s → 4s)
- 타임아웃 8초 설정 (`AbortSignal.timeout(8000)`)
- 429 (Rate Limit) 응답 시 `Retry-After` 헤더 존중

3-3. 어드민 대시보드 접근 제어 추가

대상 파일: `src/pages/AdminDashboard.tsx`, 라우터 설정

현재 `/admin` 경로는 누구나 접근 가능합니다. 매출, GA4 퍼널, 고객 데이터가 모두 외부에 노출됩니다.

```
// 현재 - 인증 체크 없음

export default function AdminDashboard() {

  const [secret, setSecret] = useState('');

  // 누구나 이 페이지에 진입 가능

}
```

개선 방향:

- 라우터 레벨에서 특정 LINE 사용자 ID 화이트리스트로 접근 제어
- 비인가 접근 시 홈으로 리다이렉트
- API 호출 시 `ADMIN_SECRET` Bearer 토큰 검증은 유지

3-4. LINE 로그인 → Shopify 고객 비밀번호 불일치 수정

대상 파일: `server/line-callback.ts`, `api/refresh-customer-token.ts`

LINE 로그인 후 Shopify 고객 생성 시 비밀번호 생성 방식이 두 곳에서 다릅니다.

위치	비밀번호 생성 방식	문제
<code>line-callback.ts</code> (회원가입)	<code>crypto.getRandomValues()</code> — 매번 다름	저장 안 함
<code>refresh-customer-token.ts</code> (토큰 갱신)	HMAC-SHA256 결정론적 생성	위와 불일치

결과: LINE 로그인 사용자의 체크아웃 토큰 갱신이 실패합니다.

개선 방향:

- 회원가입 시 HMAC 방식으로 통일하거나
- 생성된 비밀번호를 Supabase에 안전하게 저장
- `shopifyCustomerId` 를 `authStore` 에 반드시 저장

3-5. Cron 엔드포인트 보호

대상 파일: `api/slack-report.ts`, `api/instagram-follower-cron.ts`

현재 Cron 엔드포인트에 인증이 없어 누구나 직접 호출 가능합니다.

```
// 추가 필요 - Vercel Cron 헤더 검증
const cronSecret = req.headers['x-vercel-cron'];

if (cronSecret !== process.env.CRON_SECRET) {

  return res.status(401).json({ error: 'Unauthorized' });

}
```

4. P1 — 단기 처리 (1~2주)

4-1. API 에러 처리 표준화

API 호출 전반에 타임아웃과 재시도 로직이 없습니다. 특히 체크아웃 페이지에서 에러 발생 시 사용자에게 알리지 않고 조용히 실패하는 케이스가 다수 존재합니다.

```
// 현재 - 타임아웃 없음, 재시도 없음

const response = await fetch(SHOPIFY_PROXY_URL, { ... });

// 필요 - 타임아웃 + 사용자 알림

const response = await fetch(SHOPIFY_PROXY_URL, {

  signal: AbortSignal.timeout(8000),

  ...

});
```

표준화 대상:

- `src/lib/shopify.ts` — `storefrontApiRequest()`
- `src/pages/Checkout.tsx` — `fetchShippingRates()`, `fetchCartPreview()`
- 모든 `api/` 서버 함수의 외부 API 호출

4-2. LINE ID 토큰 서명 검증 강화

대상 파일: `server/line-callback.ts`

현재는 LINE API에 토큰을 전달해 클라이언트 ID만 확인합니다. RS256 서명 및 만료 시간(`exp`) 검증이 없어 토큰 위조 가능성이 있습니다.

```
// 현재 - 클라이언트 ID만 확인
body: new URLSearchParams({ id_token: idToken, client_id: channelId })

// 추가 필요

// 1. exp 클레임 확인 (토큰 만료 여부)

// 2. RS256 서명 검증 (jsonwebtoken 라이브러리)

// 3. 검증 실패 시 명확한 에러 반환 (현재는 조용히 진행)
```

4-3. CORS 와일드카드 범위 축소

대상 파일: 모든 `api/*.ts`

```
// 현재 - 너무 넓은 (다른 사용자의 Vercel 앱도 허용 가능)
/^https:\/\/smart-paw-finder[a-z0-9-]*\.vercel\.app$/

// 개선 - 정확한 도메인만 허용

const ALLOWED_ORIGINS = [

  'https://biteme.co.jp',

  'https://www.biteme.co.jp',

  'http://localhost:5173',

];
```

4-4. Admin API Rate Limiting 추가

어드민 API 엔드포인트에 Rate Limiting이 없어 무차별 대입 공격에 노출되어 있습니다. Vercel Middleware 또는 KV 기반으로 IP별 요청 횟수 제한을 구현하세요.

5. P2 — 중기 처리 (1개월)

5-1. localStorage 토큰 저장 방식 개선

현재 LINE 인증 토큰, Shopify 고객 토큰, 장바구니 데이터가 모두 localStorage에 평문 저장됩니다. XSS 취약점 발생 시 모든 토큰이 탈취됩니다.

개선 방향:

- `httpOnly` 쿠키 기반 세션 관리로 전환 (XSS로 접근 불가)
- 또는 메모리 스토어 + 새로고침 시 서버에서 재검증

5-2. CSP `unsafe-inline` 제거

대상 파일: `vercel.json`

```
// 현재 - XSS 방어 약화
"script-src 'self' 'unsafe-inline' ..."

// 개선 - nonce 기반 CSP 또는 해시 기반

"script-src 'self' 'nonce-{random}' ..."
```

5-3. 감사 로그(Audit Log) 추가

어드민 대시보드 접근, 주문 조회, 고객 데이터 열람 등 민감한 작업에 대한 로그가 없습니다. Supabase `audit_logs` 테이블을 추가하여 추적 가능하게 만드세요.

6. 즉시 실행 체크리스트

오늘 (P0)

- ☐ `SHOPIFY_CLIENT_SECRET` 교체 → Vercel 환경변수 업데이트
- ☐ `LINE_CHANNEL_SECRET` 교체 → Vercel 환경변수 업데이트
- ☐ `ANTHROPIC_API_KEY` 교체 → Vercel 환경변수 업데이트
- ☐ `GOOGLE_SERVICE_ACCOUNT_JSON` 교체 → Vercel 환경변수 업데이트
- ☐ `ADMIN_SECRET` 강화 → Vercel 환경변수 업데이트
- ☐ `SUPABASE_SERVICE_ROLE_KEY` 교체 → Vercel 환경변수 업데이트

- ☐ `.env`, `.env.vercel` → `.gitignore` 추가
- ☐ Git 히스토리에 커밋된 경우 `git filter-repo` 로 제거

이번 주 (P0 계속)

- ☐ `api/shopify.ts` — 토큰 자동갱신 로직 추가 (어제 장애 재발 방지)
- ☐ `/admin` 라우트 — LINE 사용자 ID 화이트리스트 접근 제어
- ☐ `line-callback.ts` + `refresh-customer-token.ts` — 비밀번호 일관성 수정
- ☐ Cron 엔드포인트 — `x-vercel-cron` 헤더 검증 추가

1~2주 (P1)

- ☐ 전체 API 호출에 타임아웃 + 에러 토스트 표준화
- ☐ LINE ID 토큰 서명 검증 강화 (`exp` 클레임 확인)
- ☐ CORS 와일드카드 → 정확한 도메인으로 축소
- ☐ Admin API Rate Limiting 구현

1개월 (P2)

- ☐ `localStorage` → `httpOnly` 쿠키 기반 세션 전환 검토
- ☐ CSP `unsafe-inline` 제거 (nonce 기반으로 전환)
- ☐ 감사 로그 테이블 추가

주요 대상 파일 요약

우선도	파일	이슈
● P0	<code>api/shopify.ts</code>	토큰 갱신 로직 없음 (장애 원인)
● P0	<code>.env</code> , <code>.env.vercel</code>	시크릿 키 하드코딩
● P0	<code>src/pages/AdminDashboard.tsx</code>	접근 제어 없음
● P0	<code>server/line-callback.ts</code>	비밀번호 불일치, 서명 검증 미흡
● P0	<code>api/refresh-customer-token.ts</code>	비밀번호 불일치
● P1	<code>src/lib/shopify.ts</code>	타임아웃·재시도 없음
● P1	<code>src/pages/Checkout.tsx</code>	에러 시 사용자 알림 없음
● P1	모든 <code>api/*.ts</code>	CORS 와일드카드, Rate Limiting 없음
● P2	<code>vercel.json</code>	CSP <code>unsafe-inline</code>
● P2	<code>src/stores/authStore.ts</code>	<code>localStorage</code> 토큰 저장

본 리포트는 2026-06-05 기준 코드 정적 분석 결과입니다. 코드 변경 시 해당 항목을 재검토하세요.